

Research Report: Common Network Security Threats



Author: Ayesha Azhar

Submitted to: Oasis infoByte

Task 4: A Research Report on Attack Mechanics, Real-World Impact, and Mitigation Strategies

Deadline: 15th July, 2026.

Abstract:

As businesses become increasingly dependent on digital infrastructure that is interconnected, threats to network security continue to grow in size and sophistication. Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) attacks, Man-in-the-Middle (MITM) attacks, IP spoofing, and DNS poisoning/spoofing are the four most serious threats to modern networks that are the subject of this report. The report discusses each threat's underlying attack mechanics, a real-world incident that has been documented, and the financial, operational, and reputational consequences of each, such as the 2016 Mirai botnet attack on Dyn, the 2011 DigiNotar certificate authority breach, the 1994 Kevin Mitnick–Tsutomu Shimomura IP spoofing incident, and the 2018 BGP hijack of Amazon's Route 53 DNS service. For each threat, CISA, NIST, and MITRE ATT&CK's previous guidance is used to suggest three distinct, implementable mitigation strategies. Network administrators can use this comparative analysis to sort defenses by attack vector, population at risk, technical difficulty of execution, and ease of mitigation. The report concludes that misplaced trust in unverified sources, certificates, addresses, or routes is the root cause of these threats, and that tested incident response planning and layered protocol-level defenses are necessary to reduce the likelihood and cost of successful attacks.

Table of Contents

1. Introduction -----	4
2. Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) Attacks -----	4
3. Man-in-the-Middle (MITM) Attacks -----	5
4. IP Spoofing -----	6
5. DNS Poisoning / Spoofing (Bonus Threat) -----	7
6. Comparative Analysis of Threats -----	8
7. Conclusion -----	10
8. References -----	10

1. Introduction

The attack surface available to adversaries has never been greater because modern organizations run everything from banking and email to healthcare records and industrial control systems on interconnected networks. In a matter of minutes, a single successful network-layer attack could shut down a hospital, deplete a company's bank account, or reveal the private communications of hundreds of thousands of individuals. Since many fundamental Internet protocols, such as TCP/IP and DNS, predate the modern threat landscape by decades, threat actors—ranging from lone hobbyists to organized crime syndicates and nation-state operators—constantly probe networks for weaknesses in protocols, trust relationships, and infrastructure. These infrastructures were frequently never designed with security as a primary goal. Therefore, it is essential for anyone in charge of protecting a network to have an understanding of how these threats operate, the actual damage they have historically caused, and the available concrete mitigations. DoS/DDoS attacks, Man-in-the-Middle attacks, IP spoofing, and DNS poisoning/spoofing are the four most persistent and consequential threats to network security that are the subject of this report. It examines these threats through the lens of their mechanics, actual incidents, the impact on businesses, and practical countermeasures.

2. Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) Attacks

What It Does

A Denial-of-Service (DoS) attack occurs when an adversary overburdens a target system, service, or network with traffic or requests to the point where the resource can no longer respond to legitimate users, effectively shutting it down. Similar to a botnet of compromised, internet-connected devices controlled remotely by the attacker, a distributed denial-of-service (DDoS) attack is carried out simultaneously from a large number of machines. Volumetric attacks, which consume all available bandwidth, protocol attacks, which exploit weaknesses in network protocols (such as SYN floods that abuse the TCP three-way handshake), and application-layer attacks, which target vulnerabilities in specific applications or services running on a server, are the three main types of DDoS techniques that are classified by CISA, the FBI, and the Multi-State Information Sharing and Analysis Center (MS-ISAC).

Real-World Example

On October 21, 2016, the DNS provider Dyn was hit by three coordinated waves of DDoS traffic generated by the Mirai botnet, a network of compromised Internet-of-Things (IoT) devices like home routers, IP cameras, and DVRs that had been infected after the malware brute-forced their weak, factory-default credentials. This was one of the most disruptive DDoS incidents in Internet history. The attack caused widespread outages for services like Twitter, Netflix, Amazon, PayPal, Spotify, Reddit, and GitHub in large parts of the United States and Europe due to Dyn's DNS infrastructure's conversion of domain names into IP addresses. The attack is thought to have involved roughly 100,000 compromised IoT devices, and Dyn's servers reportedly received traffic from tens of millions of distinct IP addresses simultaneously.

Impact

- Dutzende of major internet platforms that millions of users rely on were affected by widespread, multi-hour outages.
- Direct revenue loss occurred for organizations that rely on continuous availability; industry estimates place average DDoS recovery costs in the millions of dollars.
- Dyn suffered long-term reputational harm, and thousands of customer domains left the service as a result.
- The incident brought to light the systemic danger posed by internet-scale weaponization of unsecure consumer IoT devices.

Solutions for Reducing Risk

1. Services for traffic scrubbing and DDoS protection: As suggested by CISA, enroll critical infrastructure in a dedicated DoS/DDoS protection service (such as a cloud scrubbing provider or CDN) that filters malicious packets before they reach the origin server and identifies abnormal traffic patterns.
2. Configure firewalls, load balancers, and web application firewalls (WAFs) to impose connection/request rate limits, discard malicious packets, and limit traffic to only what is necessary for legitimate business purposes. This is known as rate limiting and network hardening. A fundamental recommendation of the joint CISA/FBI/MS-ISAC DDoS guidance is to keep a documented DDoS response plan that defines detection thresholds, escalation paths with ISPs/CSPs, and out-of-band communication channels so that mitigation and recovery begin immediately after an attack is confirmed.

3. Man-in-the-Middle (MITM) Attacks

What It Does

A Man-in-the-Middle (MITM) attack involves an adversary sneaking in between two parties that are communicating, such as a web server and a user's browser, and intercepting, reading, or altering the traffic without either party being aware that the channel has been compromised. MITM attacks can be achieved through several techniques, including ARP spoofing on a local network, rogue Wi-Fi access points, DNS manipulation, or — as in the example below — the abuse of a fraudulently issued digital certificate that tricks a browser into trusting an impostor server as if it were the legitimate one.

Real-World Example

In 2011, an intruder broke into the Dutch certificate authority DigiNotar and issued more than 500 bogus SSL certificates, one of which was for the wildcard domain *.google.com. Over the course of several weeks, that erroneous certificate was used in a large-scale MITM campaign against approximately 300,000 internet users, the vast majority of whom were located in Iran. The goal of the campaign was to redirect Gmail traffic through attacker-controlled servers in order to intercept the credentials and communications of the victims. An Iranian Gmail user posted a certificate warning to Google's help forum, which led to DigiNotar as the source of the problem. The

repercussions were severe: DigiNotar's root certificates were placed on a permanent blacklist by major browser manufacturers; the Dutch government took control of the business; and DigiNotar was forced into bankruptcy within weeks of the disclosure.

Impact

- The fact that the communications and credentials of approximately 300,000 users were supposedly encrypted were intercepted undermines trust in the certificate authority (CA) ecosystem that supports HTTPS.
- It is widely believed that the incident made it easier for the government to monitor political opponents at the state level. This demonstrates how MITM attacks can have consequences for national security, human rights, and financial interests. A CA that had been in operation for more than a decade completely failed, forcing browser vendors to redesign trust mechanisms like certificate pinning..

Mitigation Strategies

1. Use certificate pinning for high-value applications so that a browser rejects unexpected certificates even if a rogue CA issues one to enforce strong transport encryption. Require HTTPS/TLS everywhere, enable HSTS (HTTP Strict Transport Security) to prevent protocol downgrade, and use certificate validation to enforce strong transport encryption.
2. On untrusted networks, use VPNs and mutual authentication. When possible, on public or shared networks, route traffic through a trusted VPN and use mutual TLS or client certificates to verify both endpoints, not just the server.
3. In order to guard against ARP spoofing and rogue-device MITM techniques on internal LANs, deploy dynamic ARP inspection, DHCP snooping, and 802.1X port-based network access control on switches.

4. IP Spoofing

How It Works

IP spoofing is a technique in which an attacker crafts packets with a forged ("spoofed") source IP address, making traffic appear to originate from a trusted host rather than the actual attacking machine. This is commonly used to bypass IP-based access controls, hide the attacker's true identity, or — combined with predictable TCP sequence numbers — to hijack a trusted session outright by impersonating one of the legitimate endpoints in a connection.

Real-World Example

One of the earliest and most famous demonstrations of IP spoofing occurred on Christmas Day, 1994, when hacker Kevin Mitnick attacked the home computer of security researcher Tsutomu Shimomura. Mitnick exploited a trust relationship between two of Shimomura's machines: he sent a

flood of SYN packets to silence one trusted host, then forged that host's IP address while predicting the target's TCP sequence numbers well enough to complete a fake handshake blind — without ever seeing the responses himself — ultimately gaining root access to Shimomura's system. The attack led to a widely publicized manhunt; Shimomura assisted the FBI in tracking Mitnick down using cellular signal triangulation, and Mitnick was arrested in Raleigh, North Carolina, in February 1995. The incident is widely credited with pushing the security community to abandon predictable TCP sequence numbers and IP-address-based trust models.

Impact

- Demonstrated that IP-address-based authentication ("trusted host" relationships) could be completely defeated without ever compromising credentials.
- Directly influenced changes to TCP/IP stack implementations, including the move toward randomized initial sequence numbers to prevent blind session hijacking.
- Established IP spoofing as a foundational technique still used today as a building block for reflection/amplification DDoS attacks and evasion of access-control lists.

Mitigation Strategies

1. Ingress/egress filtering (BCP 38): Configure routers and ISPs to reject packets with source addresses that could not legitimately originate from the network segment they arrive on, preventing spoofed packets from ever reaching the wider internet.
2. Reverse Path Forwarding (uRPF) and randomized TCP sequence numbers: Enable Unicast Reverse Path Forwarding on network devices to drop packets whose source address doesn't match a valid return route, and ensure operating systems use cryptographically randomized initial sequence numbers to prevent blind spoofing/session hijacking.
3. Avoid IP-based trust; use strong authentication instead: Replace legacy "trusted host" services (like rsh) with authenticated, encrypted protocols such as SSH, and pair network access control with multi-factor authentication rather than relying on source IP address alone.

5. DNS Poisoning / Spoofing (Bonus Threat)

How It Works

DNS poisoning (also called DNS spoofing or cache poisoning) occurs when an attacker corrupts the records held by a DNS resolver or redirects DNS traffic so that a domain name resolves to a malicious IP address instead of the legitimate one. This can be achieved by exploiting weaknesses in the DNS protocol itself, compromising a DNS server's cache, or — as in the example below — manipulating the internet's routing layer (BGP) to reroute DNS queries to an attacker-controlled server entirely.

Real-World Example

On April 24, 2018, attackers executed a BGP (Border Gateway Protocol) hijack against Amazon's Route 53 DNS service in order to redirect traffic intended for the cryptocurrency wallet site MyEtherWallet.com. By fraudulently announcing more specific BGP routes for several of Amazon's IP address blocks through a compromised network (eNet, AS10297), the attackers convinced internet routers worldwide to send Route 53 DNS traffic to a malicious server hosted in Chicago instead of Amazon's real infrastructure. That rogue server then resolved MyEtherWallet.com to a phishing site hosted in Russia, and users who ignored the resulting SSL certificate warning had their wallets drained. The hijack lasted about two hours before routes were restored, but attackers made off with approximately \$150,000 in Ethereum. Other Route 53 customers, including Instagram and CNN, experienced collateral disruption during the same window.

Impact

- Direct financial theft (~\$150,000) from end users whose funds could not be recovered due to the irreversible nature of cryptocurrency transactions.
- Demonstrated that DNS poisoning does not require compromising the target's own servers at all — manipulating internet routing infrastructure (BGP) was sufficient to redirect trusted DNS traffic.
- Highlighted collateral damage: unrelated companies relying on the same DNS provider (Route 53) experienced disruption despite not being the intended target.
- Reinforced industry calls for wider adoption of routing security frameworks such as MANRS (Mutually Agreed Norms for Routing Security).

Mitigation Strategies

1. Deploy DNSSEC: Implement DNS Security Extensions (DNSSEC) to cryptographically sign DNS records so resolvers can verify that responses have not been tampered with in transit.
2. Adopt BGP route origin validation: Implement Resource Public Key Infrastructure (RPKI) and Route Origin Authorizations (ROAs) so networks can automatically reject illegitimate BGP route announcements, directly addressing the attack vector used against Route 53.
3. Harden DNS resolver configuration and monitoring: Disable unnecessary recursive DNS resolution, randomize query source ports and transaction IDs to resist cache-poisoning guesses, and continuously monitor authoritative DNS responses and BGP announcements for unexpected changes.

6. Comparative Analysis of Threats

The table below summarizes each threat across four dimensions relevant to a network administrator's risk-prioritization process: how the attack is carried out, which types of organizations or users are most exposed, how technically difficult the attack is to execute, and how readily available and effective the corresponding mitigations are.

Threat	Primary Attack Vector	Who Is at Risk	Difficulty to Execute	Ease of Mitigation
DoS / DDoS	Volumetric traffic floods, protocol abuse (e.g., SYN floods), or application-layer request floods, often via a botnet	Any internet-facing service; especially high-availability businesses (e-commerce, DNS/CDN, gaming, finance)	Low–Medium	Medium
Man-in-the-Middle	Interception via rogue certificates, ARP spoofing, rogue Wi-Fi, or DNS manipulation	Users on public/untrusted networks; organizations with weak PKI/certificate practices	Medium–High	Medium
IP Spoofing	Forging the source IP address of packets to bypass trust or impersonate a host	Systems relying on IP-based trust/allowlists; also enables reflection/amplification DDoS against third parties	Low–Medium	High
DNS Poisoning / Spoofing	Corrupting DNS cache entries or hijacking routing (e.g., BGP) to redirect domain resolution	Any organization/user relying on unauthenticated DNS/BGP; high-value targets like financial and crypto platforms	Medium–High	Medium

7. Conclusion

Three key takeaways emerge from this analysis for a network administrator:

1. Trust must be continuously verified, never assumed. Every threat examined in this report — DDoS botnets, MITM certificate abuse, IP spoofing, and DNS/BGP hijacking — ultimately succeeds by exploiting a system's willingness to trust a source, a certificate, an address, or a route without adequate verification. Deploying cryptographic verification (TLS with pinning, DNSSEC, RPKI) and abandoning legacy IP-based trust models closes off entire classes of attack.
2. Layered, protocol-level defenses are more resilient than any single control. No single tool stops all four threats; a combination of ingress/egress filtering, rate limiting, DDoS scrubbing services, strong PKI hygiene, and routing security (MANRS/RPKI) is required, and these controls are most effective when implemented at the ISP, cloud provider, and organizational levels simultaneously rather than relying on the origin server alone.
3. Preparedness determines the real-world cost of an incident. In nearly every case study above — Dyn, DigiNotar, and the Route 53/MyEtherWallet hijack — the technical compromise itself lasted hours, but the reputational and financial damage persisted far longer, in DigiNotar's case ending the company entirely. A documented incident response and business continuity plan, tested before an attack occurs, is what separates a contained incident from a catastrophic one.

8. References

1. Cybersecurity and Infrastructure Security Agency (CISA), FBI, and MS-ISAC. Understanding and Responding to Distributed Denial-of-Service Attacks. cisa.gov/resources-tools/resources/understanding-and-responding-distributed-denial-service-attacks
2. Cybersecurity and Infrastructure Security Agency (CISA). Understanding Denial-of-Service Attacks. cisa.gov/news-events/news/understanding-denial-service-attacks
3. Cybersecurity and Infrastructure Security Agency (CISA). Mitigating DDoS Attacks. cisa.gov/news-events/alerts/2020/06/03/mitigating-ddos-attacks
4. MITRE ATT&CK. Network Denial of Service, Technique T1498. attack.mitre.org/techniques/T1498/
5. MITRE ATT&CK. Adversary-in-the-Middle, Technique T1557. attack.mitre.org/techniques/T1557/
6. Electronic Frontier Foundation. A Post Mortem on the Iranian DigiNotar Attack. eff.org/deeplinks/2011/09/post-mortem-iranian-diginotar-attack
8. ThousandEyes (Cisco). Anatomy of a BGP Hijack on Amazon's Route 53 DNS Service. thousandeyes.com/blog/amazon-route-53-dns-and-bgp-hijack

9. National Institute of Standards and Technology (NIST). Special Publication 800-61 Rev. 2: Computer Security Incident Handling Guide. csrc.nist.gov/pubs/sp/800/61/r2/final
10. National Institute of Standards and Technology (NIST). NIST Cybersecurity Framework. nist.gov/cyberframework
11. SANS Institute Reading Room. Network Security white paper index. sans.org/white-papers/
12. KrebsOnSecurity. Source Code for IoT Botnet "Mirai" Released. krebsonsecurity.com/2016/10/source-code-for-iot-botnet-mirai-released/
13. Wikipedia. DDoS attacks on Dyn. en.wikipedia.org/wiki/DDoS_attacks_on_Dyn